Auditoria completa do Pediatria360

Data: 01/10/2026 · Repositório `draraiany-source/pediatria360` · Branch `feat/area-profissional`
Código auditado: commit `e795e63` (local; o GitHub está em `a66f2b3` e a diferença é só a correção do calendário descrita no achado 6)
Demonstração publicada: `https://draraiany-source.github.io/pediatria360-demo/` (fonte `0c6ce5c`)

Classificação: NÃO PRONTO para as lojas, para produção nem para uso com pacientes reais. A demonstração web com dados fictícios está pronta para homologação.

1. Resumo executivo

O projeto tem duas partes que precisam ser lidas separadamente:

- **App real** (`lib/main.dart`, Firebase): login, cadastro de crianças, crescimento, vacinas, prontuário, agenda, gestão de clínica e Cloud Functions. Compila para web com `ENV=prod` e passa nos testes automatizados, mas nunca foi testado de ponta a ponta com Firebase real, não tem assinatura de loja e depende de textos legais e dados do proprietário.
- **Demonstração web** (`lib/main_demo.dart`): onde foi feito todo o trabalho desde 27/09 (pré-consulta, área da família, rotina, sono, puericultura, documentos, calculadora, agenda e acompanhamento). Funciona com dados fictícios em memória, sem login e sem servidor, e foi testada no navegador em celular e computador.

Principal achado: quase nada do que foi construído na demonstração está ligado ao app real. O app real usa só 2 dos arquivos de regras compartilhadas (`lib/shared`) e a tela de crescimento dele ainda usa a tabela da OMS aproximada; a tabela oficial está só na demonstração.

Canal	Veredito	Motivo principal
Demonstração web (GitHub Pages)	Pronta para homologação	Dados fictícios; 427/428 verificações no link público (a falha era do roteiro de teste e foi corrigida); WebKit com perfil de iPhone 14/14.
Web de produção do app real	Bloqueado	Textos legais e domínio fictícios, App Check desligado, sem teste de ponta a ponta com Firebase real, publicação das regras não verificada.
Google Play / App Store	Bloqueado	Android assina com chave de debug; iOS precisa de Mac/Xcode; contas de loja e textos legais pendentes.
Uso clínico com pacientes reais	Bloqueado	OMS aproximada no app real, calendário de vacinas a conferir, conteúdo clínico em rascunho, LGPD sem controlador definido.

2. Escopo e método

Verificado nesta auditoria (01/10/2026)

- Código atual da branch `feat/area-profissional`, Cloud Functions, regras do Firestore e do Storage, integração contínua e PRs no GitHub.
- Execução de: `flutter test`, `flutter analyze`, build web do app real com `ENV=prod`, `tsc`, Jest e ESLint das Functions, teste offline das regras e `npm audit`.
- Varredura de chaves, senhas e dados pessoais no código e no site publicado.
- Resultados dos testes de navegador no link público de 30/09 (mesma fonte publicada).

Não verificado

- Projeto Firebase de produção: deploy de regras, índices e Functions (exige acesso ao console).
- Testes de regras no emulador nesta máquina (Java não instalado); vale a última execução no GitHub.
- iPhone e Android físicos; build Android e iOS.
- Fluxos com login real e dados reais (proibido por política).
- Revisão jurídica e clínica de conteúdo.

3. Estado do repositório e da entrega

Item	Situação verificada
Branch principal (`main`)	Parada em `988de4d` desde 26/09.
Branch de trabalho	`feat/area-profissional`, 77 commits à frente do `main`, nenhum integrado.
Pull requests	6 abertos, nenhum integrado. Estão encadeados: #6 (esta branch) aponta para `demo/web-homolog` (#5), que aponta para `handoff/final-20260926`. Os PRs #1 a #4 apontam para o `main`.
Integração contínua	O fluxo principal (CI) só roda em `main` / `develop`: não rodou nesta branch. A última execução, em 26/09 na branch `visual/capi-avatars-3d`, terminou com falha. O fluxo de regras do Firestore passou em 27/09.
Alteração local fora do commit	`lib/demo/screens/business_screens.dart` (só troca de fim de linha; não deve ser enviado).
Documentos antigos na raiz	Cerca de 40 arquivos de auditoria, fase e checklist entre 16 e 26/09. Vários estão desatualizados (por exemplo, `BLOQUEADORES_PRODUCAO.md` ainda diz que nenhuma linha foi compilada). Este documento os substitui como fotografia atual.

Tamanho do código

Pasta	Conteúdo	Arquivos Dart	Linhas
`lib/features`	App real, 26 módulos	187	51.299
`lib/demo`	Demonstração web	48	35.236
`lib/shared`	Regras compartilhadas (clínica, pré-consulta, rotina, agenda, IA)	65	14.916
`lib/core`	Configuração, roteamento, serviços	51	8.451
`test`	Testes automatizados	84	15.741
`functions/src`	Cloud Functions (TypeScript, região `southamerica-east1`)	15 arquivos, cerca de 50 funções chamáveis ou gatilhos	

Stack: Flutter 3.44.4 estável (SDK Dart ≥ 3.8 no pubspec), Riverpod, go_router, Firebase (Auth, Firestore, Storage, Functions, Messaging, Crashlytics, App Check preparado), pdf/printing.

4. Testes e builds executados

Verificação	Resultado	Observação
`flutter test` (suíte completa)	769/769	A primeira rodada de hoje deu 768/769: estouro de layout no calendário da rotina em tela de 320 px, que só aparece em outubro. Corrigido (achado 6) e repetido.
`flutter analyze`	0 erros, 0 avisos	132 apontamentos informativos de estilo, todos antigos.
Build web do app real (`lib/main.dart` , `ENV=prod`)	Compila	233 s, sem erros. Prova só a compilação: não houve teste de uso com Firebase.
Build da demonstração	Compila	Varredura de termos proibidos sem ocorrências (30/09).
Cloud Functions: TypeScript (`tsc --noEmit`)	Sem erros	
Cloud Functions: Jest	25/25	Agendamento, WhatsApp e voz.
Cloud Functions: ESLint	1 aviso	0 erros.
Regras do Firestore: teste offline	4/4	Estrutura das regras de isolamento por clínica.
Regras do Firestore: emulador	Não executado aqui	Java ausente. No GitHub passou em 27/09, e as regras atuais são idênticas às testadas.
Navegador no link público (Chrome, computador 1366 px e celular 390 px)	427/428	30/09. A falha era do roteiro (contador fora da tela) e passou 5/5 depois do ajuste.
WebKit com perfil de iPhone 15 no link público	14/14	30/09. Emulação; não substitui um iPhone real.
Calculadora, bloco "dose máxima" no navegador	Intermitente	Às vezes perde a digitação depois de o campo ser apagado (achado 7).
Android (APK/AAB) e iOS	Não executado	Sem chave de release; iOS exige Mac.

5. Segurança e privacidade

Ponto	Situação	Detalhe
Segredos no repositório	Nenhum encontrado	Sem chaves privadas, tokens, senhas ou contas de serviço versionados. `key.properties` , `*.jks` , `google-services.json` e `.secret.local` estão no `.gitignore` .
Chaves Firebase de cliente	Versionadas	`lib/firebase_options.dart` tem 4 chaves de API do Firebase. Elas não são segredo (vão para todo cliente), mas precisam de restrição por app e domínio no Google Cloud e de App Check para evitar abuso.
Site da demonstração	Limpo	Sem chaves, senhas, CPFs ou endereços do Firebase; e-mails `@exemplo.invalid` , telefones `90000-000x` , CRM `00000-UF` . A política de segurança só permite o próprio site.

Regras do Firestore e do Storage	Prontas, publicação não verificada	1.010 e 39 linhas, com isolamento por criança, por responsável e por clínica. O isolamento por unidade (`unitId`) existe só no app. Não há regras para os módulos novos (pré-consulta da família, liberação de documentos, rotina), porque eles não existem no app real.
App Check	Preparado, desligado	Liga com `ENABLE_APP_CHECK=true`; as regras ainda não exigem o token. Na web precisa da chave do reCAPTCHA.
Modo de desenvolvimento	Bloqueado em produção	`DevMode` nunca liga com `ENV=prod`. O padrão sem a variável é `dev`: builds de loja precisam de `--dart-define=ENV=prod`.
Dependências das Functions	8 moderadas	`npm audit` (produção): 0 altas, 0 críticas.
LGPD	Técnica parcial	Exportar e excluir dados e consentimento existem no código. Faltam controlador (CNPJ), encarregado de dados, e-mail de suporte e domínio reais, Termos e Política (URLs fictícias em `pediatria360.app`).
Separação de acesso na demonstração	Testada	Responsável vê só as próprias crianças e documentos liberados; recepção, financeiro e administrador bloqueados nas áreas clínicas e da família. Vale só para a demonstração: no app real, depende das regras do Firestore.

6. Funcionalidades: status real

Legenda: **Funcional** funciona e foi testado no ambiente indicado · **Parcial** funciona com lacunas · **Simulado** só demonstra o fluxo · **Desligado** código preparado, desligado por configuração · **Não feito** não existe. "Demo" = demonstração web com dados fictícios em memória. "App real" = Firebase, sem teste de ponta a ponta com login real.

6.1 Fluxo da família e da criança

Funcionalidade	Demo	App real	Tela / origem dos dados	Pendência
Acesso separado por responsável e criança	Funcional	Parcial	Perfil escolhido na demo; Firebase Auth e vínculo de responsáveis no app	App real: teste de ponta a ponta com login real e regras publicadas.
Pré-consulta (queixas, sintomas, fotos, exames)	Funcional	Parcial	`#/pre-consulta/:id`; questionário de teleconsulta no app	Fotos e exames no app real; resumo organizado só na demo.
Agenda: solicitar, confirmar, remarcar	Funcional	Parcial	Agenda e assistente na demo; agendamento de teleconsulta no app	Assistente de horários com respostas simuladas.
Lembretes e orientações prévias	Simulado	Não feito	Painel de lembretes com enviado, falhou e pendente	WhatsApp oficial (credenciais Meta); orientações padrão sem revisão clínica.
Diário (mamadas, fraldas, banho, sono, temperatura, peso) com calendário	Funcional	Não feito	`#/rotina/:id`; memória da aba	Gravação no Firestore e regras.
Sono com linha do tempo	Funcional	Não feito	Aba Sono da rotina	Levar ao app real.
Saúde e desenvolvimento	Funcional	Parcial	`#/rotina/:id/saude`; crescimento e vacinas no app	Lista de marcos de exemplo; decidir quais estados a família vê.

Curvas de crescimento	Funcional	Parcial	Demo: tabelas LMS oficiais da OMS; app: tabela aproximada	Trocar a tabela do app real pela oficial.
Calendário de vacinação	Parcial	Parcial	Calendário PNI de referência	Conferir com o gov.br (aviso visível).
Pós-consulta: documentos liberados	Funcional	Não feito	`#/rotina/:id/documentos`	Levar a liberação ao app real.

6.2 Fluxo do profissional

Funcionalidade	Demo	App real	Tela / origem dos dados	Pendência
Agenda diária e semanal, pacientes sem retorno	Funcional	Parcial	Agenda dia/semana/mês e acompanhamento na demo; agenda do profissional no app	Acompanhamento de retorno só na demo.
Histórico e observações por consulta	Funcional	Parcial	Prontuário e histórico; prontuário eletrônico no app	CID só por código digitado.
Anamnese, exame, hipóteses, conduta, retorno	Funcional	Parcial	Consulta em etapas	Hipóteses e resumo da consulta só na demo.
Puericultura (5 etapas, marcos, idade corrigida)	Funcional	Não feito	Consulta de puericultura	Marcos e modelos precisam de revisão clínica.
Modelos próprios	Parcial	Não feito	Receitas, orientações por faixa e evolução de puericultura	Modelos de atestado e encaminhamento a criar.
Documentos com logomarca, PDF e impressão	Funcional	Parcial	Receita, atestado, encaminhamento, exames, orientações	Sem assinatura ICP-Brasil: documentos "Não assinado".
Calculadora de doses com revisão obrigatória	Funcional	Parcial	Referências fictícias de teste	Referências reais validadas; achado 7.
Vitaminas, suplementação, exames laboratoriais	Parcial	Parcial	17 temas em rascunho, sem conteúdo clínico	Conteúdo licenciado e revisado.
IA: resumo e rascunhos com rótulo e revisão humana	Simulado	Parcial	Resumo por regras e rascunho simulado; chat de IA nas Functions	IA real desligada na demo; revisar cotas e custos.
Teleconsulta	Protótipo	Desligado	`videoConsultationEnabled = false`	Contratar provedor de vídeo.

6.3 Comunicação, gestão e plataforma

Funcionalidade	Demo	App real	Tela / origem dos dados	Pendência
Regras de lembrete com consentimento	Funcional	Não feito	Lembretes na demo	Levar ao app real.
WhatsApp oficial (mensagens administrativas)	Simulado	Preparado	`functions/src/whatsapp.ts`, testado e sem gatilho publicado	Conta Meta, número, modelos aprovados.
Pagamentos	–	Desligado	`paymentGatewayEnabled = false`	Contratar gateway.

Financeiro, faturamento, estoque, BI, auditoria	Parcial	Parcial	Módulos de gestão	Sem operador TISS; homologação incompleta.
Visual navy, tema claro/escuro	Não feito	Não feito	–	Próxima etapa combinada.
Celular e computador	Funcional	Parcial	Demo testada em 320, 390, 430 e 1366 px	App real sem teste em aparelho.

7. Achados desta auditoria

#	Gravidade	Achado	Evidência e recomendação
1	Alta	Os módulos novos existem só na demonstração	O app real importa apenas `shared/scheduling/agenda_conflicts.dart` e `shared/widgets/sync_banner.dart`. Pré-consulta organizada, área da família, rotina, sono, puericultura e liberação de documentos precisam de repositório no Firestore, regras e telas no app real.
2	Alta	O app real usa a tabela da OMS aproximada	`lib/features/growth/domain/who_reference.dart` carrega `who_reference.json`. A tabela oficial (`who_growth_lms.json`, com fonte, commit e hashes) é usada só pela demo. Ligar o app real à tabela oficial.
3	Alta	Nada integrado ao `main`; integração contínua não roda nesta branch	6 PRs abertos e encadeados, 77 commits fora do `main`; a última integração contínua falhou em 26/09. Decidir a ordem de revisão e integração, e ligar a integração contínua também para os PRs desta cadeia.
4	Alta	Publicação do backend não verificada	Não há evidência de deploy das regras, índices e Functions no projeto de produção. Publicar as regras antes de qualquer dado real e testar no emulador.
5	Média	Chaves Firebase sem proteção adicional	Chaves de cliente versionadas e App Check desligado. Restringir as chaves no Google Cloud e ativar o App Check com as regras exigindo o token.
6	Média	Estouro no calendário da rotina em tela de 320 px (corrigido)	Aparecia em outubro, com 3 marcadores mais "+" no mesmo dia. Corrigido no commit local `e795e63`; os testes passam. Ainda não está no GitHub nem no link público.
7	Média	Calculadora: digitação perdida com acessibilidade da web ligada	No teste automatizado, ao apagar o campo de dose e digitar, a tecla às vezes se perde. Afeta o modo usado por leitores de tela. Verificar com leitor de tela e corrigir antes de uso real.
8	Média	Functions: dependências e funções preparadas	8 vulnerabilidades moderadas; 1 aviso de lint. Agendamento e WhatsApp têm código e testes, mas nenhum gatilho publicado. Atualizar dependências antes do deploy.
9	Média	Assinatura e plataformas nativas	Android assina release com chave de debug; iOS sem build. Criar a chave de release e montar o build iOS num Mac.
10	Baixa	Documentação antiga desatualizada	Cerca de 40 arquivos de auditoria na raiz com afirmações vencidas. Mover para uma pasta de histórico e manter este relatório como referência.
11	Baixa	Avisos de estilo do analisador	132 apontamentos informativos, sem erros. Limpar aos poucos.

8. Bloqueadores para publicação

#	Bloqueador	O que falta
1	Textos legais e dados do controlador	Termos de Uso, Política de Privacidade, CNPJ, encarregado de dados, e-mail de suporte e domínio reais.
2	Firebase de produção	Confirmar o projeto, publicar regras, índices e Functions, restringir chaves, autorizar domínios e SHA do Android, ativar o App Check.
3	Módulos novos fora do app real	Achado 1: levar ao app real com regras e testes.

4	Dados clínicos	OMS oficial no app real, conferência do calendário PNI, revisão de marcos, orientações, modelos e calculadora.
5	Assinatura e lojas	Chave de release Android, build iOS, contas Google Play e Apple Developer, ficha das lojas sem prometer vídeo, pagamento ou ICP-Brasil.
6	Homologação do app real	Ponta a ponta com login real em aparelhos, exportar e excluir dados (LGPD), separação de acesso por perfil nas regras.
7	Integração do código	Revisar e integrar a cadeia de PRs ao `main` com integração contínua passando.

9. O que depende de você ou de terceiros

Credenciais e serviços externos

- Projeto Firebase de produção e acesso ao console.
- WhatsApp Business (Meta): número, token e modelos aprovados.
- Provedor de IA para uso real (chave nas Functions) e limites de custo.
- Provedor de vídeo para a teleconsulta.
- Gateway de pagamento.
- Certificado ICP-Brasil para assinatura de documentos.
- Contas Google Play e Apple Developer; Mac com Xcode.

Revisão clínica e jurídica

- Calendário PNI; marcos do desenvolvimento.
- Textos de orientação (antes da consulta e por faixa etária) e modelos de evolução.
- Referências da calculadora de doses (hoje fictícias).
- Biblioteca de suplementação (17 temas em rascunho; conteúdo de terceiros exige licença).
- Termos de Uso e Política de Privacidade.

Decisões suas

- Ordem de integração dos 6 PRs ao `main`.
- Quando levar os módulos da demonstração ao app real e em qual ordem.
- Quais estados de marcos a família vê (hoje só "Adquirido").
- Se receita, atestado, encaminhamento e exames continuam exigindo liberação explícita para a família.
- Envio do commit `e795e63` e nova publicação da demonstração.

10. Plano recomendado

1. Revisar e integrar a cadeia de PRs ao `main`, com a integração contínua ligada e passando.
2. Ligar o app real à tabela oficial da OMS (rápido, alto impacto clínico).
3. Levar ao app real, nesta ordem: pré-consulta organizada, liberação de documentos para a família, rotina e sono, puericultura. Cada um com repositório, regras do Firestore e testes no emulador.
4. Configurar o Firebase de produção: regras, índices, Functions, App Check e restrição de chaves.
5. Concluir o visual navy com tema claro e escuro (etapa combinada) e os modelos de atestado e encaminhamento.
6. Revisão clínica e jurídica dos conteúdos e textos legais.
7. Homologar o app real com login em iPhone e Android físicos, e só então preparar as lojas.

11. Anexo: comandos executados

Comando	Resultado
`flutter test --reporter expanded`	769 aprovados (após a correção do achado 6)
`flutter analyze`	132 informativos, 0 erros, 0 avisos
`flutter build web -t lib/main.dart --release --dart-define=ENV=prod`	Build concluído
`npx tsc --noEmit` (functions)	Sem erros
`npx jest` (functions)	3 suítes, 25 testes aprovados
`npx eslint src` (functions)	0 erros, 1 aviso
`npm audit --omit=dev` (functions)	8 moderadas, 0 altas, 0 críticas
`npm run test:offline` (tools/firestore-rules-tests)	4 aprovados
`node tools/demo/e2e_clinico.js` (link público, 30/09)	427/428; falha do roteiro corrigida e repetida (5/5)
`node tools/demo/smoke_ios.js` (link público, 30/09)	14/14

Este relatório foi gerado a partir do código e dos testes executados em 01/10/2026. Não contém dados de pacientes, senhas nem chaves. Não afirma que o aplicativo está pronto para publicação.